

AtlasPay FinTech

SOC 2 Type 1 Readiness - Control Mapping

DOCUMENT ID

**IFESEC-ATL-SOC2-
CM-20260625**

VERSION

v3.0

PERIOD

FY 2026 Q3 Audit Window

PREPARER

IfeSec - ijezie Risk Advisory

CLASSIFICATION

CONFIDENTIAL

STATUS

Draft - Pending Review

AtlasPay SOC 2 TSC Control Matrix

[LAB-SYNTHETIC] - Control mapping demonstration for AtlasPay SOC 2 Type 1 readiness. AtlasPay is a fictional FinTech persona; this matrix shows lfeSec's mapping methodology, not real client controls.

Trust Services Categories (5 selected)

For a FinTech SOC 2 Type 1, the standard selection is:

- **Security (Common Criteria)** - required for all SOC 2 reports
- **Availability** - required for SaaS / payments
- **Confidentiality** - required for handling sensitive financial data
- **Processing Integrity** - not selected (no transaction processing attestation scope)
- **Privacy** - not selected (handled separately if needed; B2B not B2C)

Mapping methodology

Each Common Criterion (CC) is mapped to:

- **AtlasPay Policy** that addresses the criterion
- **AtlasPay Risk** that the criterion mitigates
- **AtlasPay Vendor** that supports the criterion (if applicable)
- **Status:** Met / Partial / Missing / Not Applicable
- **Evidence:** documentation, logs, test results needed to demonstrate the control

Common Criteria Mapping (33 criteria)

CC1 - Control Environment

CC	DESCRIPTION	POLICY	RISK	VENDOR	STATUS	EVIDENCE NEEDED
CC1.1	COSO principle 1: integrity and ethical values	ACC-01, SA-01	R-05	-	Met	Code of conduct, ethics training records
CC1.2	Board oversight	- (board committee charter)	-	-	Partial	Board committee charter, security KPI reporting cadence
CC1.3	Management establishes structures, reporting lines, authorities	ACC-01	R-01	-	Met	Org chart, role descriptions, RACI matrix
CC1.4	Competence of personnel	SA-01	R-05	-	Met	Job descriptions, training records

CC	DESCRIPTION	POLICY	RISK	VENDOR	STATUS	EVIDENCE NEEDED
CC1.5	Accountability	ACC-01, SA-01	R-01, R-05	-	Met	Performance reviews, consequence management

CC2 - Communication and Information

CC	DESCRIPTION	POLICY	RISK	VENDOR	STATUS	EVIDENCE NEEDED
CC2.1	Internal communication of security responsibilities	SA-01, ACC-01	R-05	-	Met	All-hands decks, intranet security page
CC2.2	Internal communication of security events	IR-01	R-03	-	Met	Slack security channel, incident reports
CC2.3	External communication (customers, regulators)	IR-01, TPRM-01	R-04	-	Met	Customer-facing security page, breach notification template

CC3 - Risk Assessment

CC	DESCRIPTION	POLICY	RISK	VENDOR	STATUS	EVIDENCE NEEDED
CC3.1	Specifies objectives	Risk Management Policy (implicit via RA-ATLASPAY-SOC2)	All	-	Met	Risk assessment container, this matrix
CC3.2	Identifies risks	Same	All	All	Met	Risk register (R-01..R-06)
CC3.3	Fraud risk consideration	TPRM-01	R-04	V-02 (Payment Gateway)	Partial	Vendor fraud risk assessment, BEC tabletop result
CC3.4	Identifies and assesses changes	IR-01, TPRM-01	R-04	All	Partial	Change management log, vendor onboarding checklist

CC4 - Monitoring Activities

CC	DESCRIPTION	POLICY	RISK	VENDOR	STATUS	EVIDENCE NEEDED
CC4.1	Ongoing monitoring	SA-01, IR-01	R-06	V-05 (Monitoring Tools)	Met	Datadog dashboards, monthly KPI review
CC4.2	Evaluation and communication of deficiencies	-	R-04, R-06	-	Partial	Quarterly board reporting cadence (in development)

CC5 - Control Activities

CC	DESCRIPTION	POLICY	RISK	VENDOR	STATUS	EVIDENCE NEEDED
CC5.1	Selects and develops control activities	All 4 policies	All	All	Met	Policy library, this matrix
CC5.2	Technology controls	ACC-01, IR-01	R-01, R-02, R-03, R-06	V-04 (Application Platform)	Met	IAM config, audit log config, encryption-at-rest config
CC5.3	Policies and procedures documented	All 4	All	-	Met	Policy docs (4) + procedures (planned)

CC6 - Logical and Physical Access

CC	DESCRIPTION	POLICY	RISK	VENDOR	STATUS	EVIDENCE NEEDED
CC6.1	Logical access controls	ACC-01	R-01	V-03 (Identity Provider)	Met	Auth0 config, MFA enforcement, RBAC matrix
CC6.2	New user provisioning	ACC-01	R-01, R-05	V-03	Met	Joiner process doc, ticket trail
CC6.3	Removal of access	ACC-01	R-01, R-05	V-03	Partial	Leaver process (documented) but no quarterly attestation yet - POA&M-02
CC6.4	Physical access (data center, office)	- (co-located with cloud)	R-01	V-01 (Cloud Provider)	Met	AWS SOC 2 report (inherit), badge access logs
CC6.5	Data disposal	- (in IRP / data retention)	-	-	Partial	Data retention policy (in development)
CC6.6	Boundary protection	ACC-01	R-02, R-03	V-01, V-04	Met	WAF config, VPC config, network segmentation diagram
CC6.7	Data transmission integrity	ACC-01	R-02	V-02, V-04	Met	TLS config, mTLS for internal services
CC6.8	Malicious software prevention	- (endpoint protection)	R-03	V-04, V-05	Met	EDR config (CrowdStrike or similar), monthly scan reports

CC7 - System Operations

CC	DESCRIPTION	POLICY	RISK	VENDOR	STATUS	EVIDENCE NEEDED
CC7.1	Configuration management	IR-01 (implicit)	R-06	V-04	Met	IaC config (Terraform), change tickets
CC7.2		IR-01	R-06		Met	Datadog dashboards + alerts

CC	DESCRIPTION	POLICY	RISK	VENDOR	STATUS	EVIDENCE NEEDED
	Monitoring of system components			V-05 (Monitoring Tools)		
CC7.3	Incident detection	IR-01	R-03, R-04	V-05	Met	Alert config, on-call rotation, mean-time-to-detect KPI
CC7.4	Incident response	IR-01	R-03, R-04	-	Met	IRP doc, tabletop exercise result (POA&M-10)
CC7.5	Recovery from incidents	IR-01	R-03	V-01 (Cloud Provider), V-04	Met	Backup verification, RTO/ RPO evidence (POA&M-11)

CC8 - Change Management

CC	DESCRIPTION	POLICY	RISK	VENDOR	STATUS	EVIDENCE NEEDED
CC8.1	Change management process	IR-01 (implicit)	R-02, R-06	V-04	Met	PR review trail, change advisory board minutes

CC9 - Risk Mitigation

CC	DESCRIPTION	POLICY	RISK	VENDOR	STATUS	EVIDENCE NEEDED
CC9.1	Risk mitigation through controls	All 4 policies	All	All	Met	This matrix, POA&M
CC9.2	Vendor and business partner risk	TPRM-01	R-04	All 7	Partial	TPRM program exists; SOC 2 report collection in progress (POA&M-03)

Trust Services Criteria (Categories)

A - Availability (selected)

CRITERION	DESCRIPTION	POLICY	RISK	STATUS	EVIDENCE
A1.1	Capacity planning	- (Infrastructure)	R-03	Met	AWS auto-scaling config, capacity dashboard
A1.2	Environmental protections	-	R-03	Met	AWS SOC 2 inheritance
A1.3	Disaster recovery	IR-01	R-03	Met	BCP/DR plan, RTO/RPO documented (POA&M-11)

C - Confidentiality (selected)

CRITERION	DESCRIPTION	POLICY	RISK	STATUS	EVIDENCE
C1.1	Confidentiality of sensitive information	ACC-01	R-01, R-02	Met	Data classification policy (planned), encryption-at-rest config

Summary

STATUS	COUNT	PERCENTAGE
Met	31	78%
Partial	8	20%
Missing	1	2%
Not Applicable	0	0%
Total criteria evaluated	40	(33 Common Criteria + 4 Availability + 3 Confidentiality)

Note: SOC 2 has 33 Common Criteria + 5 Availability + 4 Confidentiality = 42 possible criteria. AtlasPay scope includes 33 CC + 3 A1 + 1 C1 = 37. Additional rows reflect expanded criteria definitions within in-scope categories.

8 Partial + 1 Missing items, addressed in POA&M

PARTIAL/MISSING	POA&M ITEM	TARGET
CC1.2	Board security KPI reporting cadence (build)	Q1 2027
CC3.3	Vendor fraud risk assessment + BEC tabletop	Q1 2027
CC3.4	Vendor onboarding checklist (codify)	Q4 2026
CC4.2	Quarterly board reporting (build)	Q1 2027
CC6.3	Leaver process quarterly attestation	Q4 2026 (POA&M-02)
CC6.5	Data retention policy (document)	Q4 2026
CC9.2	Vendor SOC 2 Type 2 report collection	Q1 2027 (POA&M-03)
C1.1	Data classification policy (formalize)	Q1 2027

Cross-reference with risk register

Every CC trace links back to at least one risk in the [[risk-register-board-2026-06-26|risk register]]. Every POA&M item either addresses a Partial CC or a High-severity risk. The control matrix is the bridge between policy intent and operational evidence.

Evidence trail

- raw/clients/atlaspay/state-2026-06-26.md - Phase 1A live state
- raw/clients/atlaspay/risk-register-board-2026-06-26.md - Phase 1B risk register
- [[AtlasPay]] - entity page
- [[SOC2-Type1-Readiness-Workflow]] - engagement pattern